

REPORT DI ANALISI MALWARE

Esercizio 5 – Analisi URL Sospetti con ANY.RUN

1. Introduzione e Obiettivo dell'Esercizio

In questo esercizio ho analizzato due URL sospetti attraverso la piattaforma di sandboxing interattivo ANY.RUN.

L'obiettivo era studiare il comportamento di questi link all'interno di un ambiente controllato e sicuro, capire se si trattasse di minacce reali, e formulare una raccomandazione di remediation motivata.

I task analizzati sono:

- Task 2 – <https://app.any.run/tasks/f1f20828-2222-46fb-a886-09f77581e67b/>

2. Cos'è ANY.RUN e Come Funziona

ANY.RUN è una sandbox interattiva basata su cloud che permette di eseguire file o URL sospetti in un ambiente Windows virtuale isolato. A differenza delle sandbox tradizionali, l'analista può interagire in tempo reale con il sistema durante l'esecuzione, osservando il comportamento del campione come se fosse davanti a un vero computer infetto, senza alcun rischio per i sistemi reali.

La piattaforma monitora e registra in automatico: tutti i processi avviati, le connessioni di rete, le richieste DNS e HTTP, le modifiche al registro di sistema, i file creati o modificati, e qualsiasi comportamento sospetto classificato tramite tecniche MITRE ATT&CK.

3. Analisi – Task 2: URL di Phishing Facebook (Caso Principale)

3.1 Panoramica Generale

L'analisi è stata eseguita su un sistema Windows 10 Professional a 64 bit (build 19045). La durata totale dell'esecuzione è stata di 62 secondi.

The screenshot displays the ANY.RUN platform interface for analyzing a suspicious URL. On the left, a browser window shows a Facebook login page with the text "Log into Facebook" and "MOVE YOUR MOUSE TO VIEW SCREENSHOTS". The right panel provides a comprehensive overview of the system's state during the analysis. It includes a "No threats detected" status, the URL being analyzed, and a "Total time: 62 s" duration. The "Processes" section lists several instances of chrome.exe and svchost.exe, along with their respective memory and CPU usage. The "Network" section shows outgoing connections to various domains. The "DNS Requests" section lists the domains resolved during the analysis. The "HTTP Requests" section shows the sequence of requests made by the browser. The "System" section provides details about the virtual machine, including the operating system (Windows 10 64bit) and the hardware configuration.

3.2 Cosa Succede Tecnicamente: il Flusso del Malware

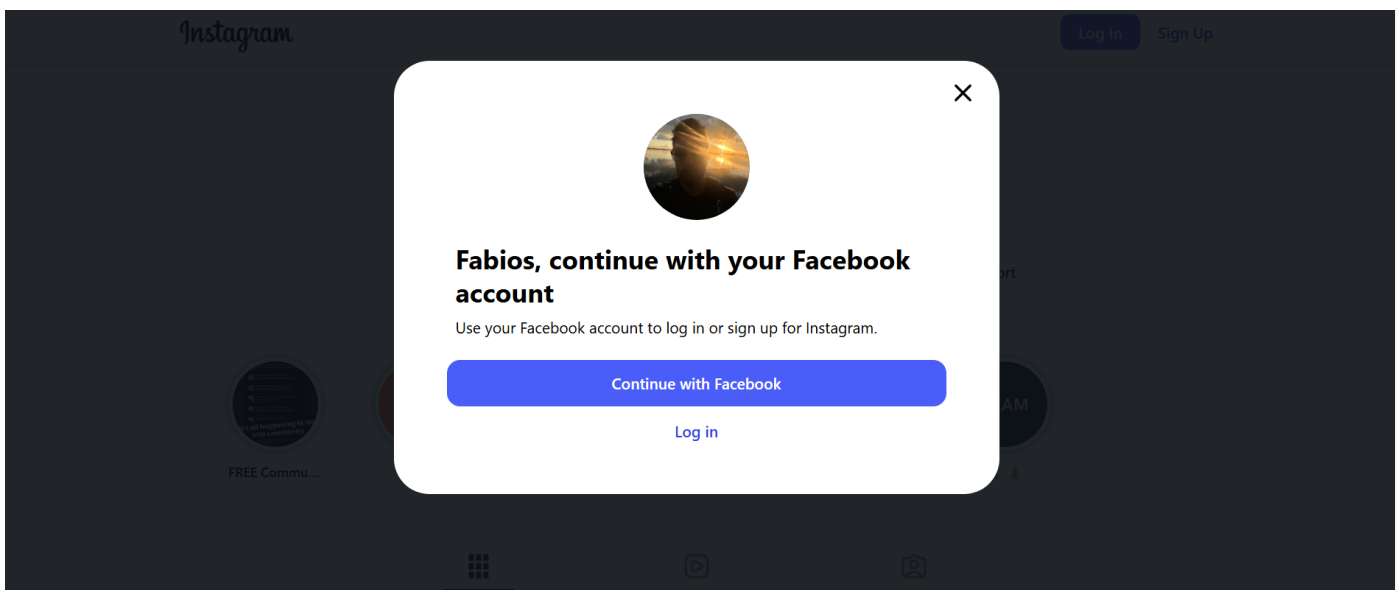
Questo URL sfrutta una tecnica di attacco comunemente chiamata Phishing tramite redirect. Ecco come funziona il processo passo dopo passo:

Fase 1 – L'esca iniziale (Redirect da ConvertKit)

Il link di partenza appartiene al dominio `click.convertkit-mail2.com`, che è un servizio legittimo di email marketing. Gli attaccanti lo utilizzano intenzionalmente perché è un dominio affidabile e difficilmente bloccato dai filtri anti-spam. L'URL contiene una lunga stringa di caratteri casuali che funge da identificatore di tracciamento. Quando la vittima clicca il link (ad esempio ricevuto via email), viene immediatamente reindirizzata senza che se ne accorga.

Fase 2 – La pagina di destinazione: Falsa pagina Facebook

Dopo il redirect, il browser della vittima apre una pagina che imita perfettamente l'interfaccia di login di Facebook. La pagina mostra i classici campi 'Email o numero di telefono' e 'Password', insieme al pulsante 'Log In'. L'utente non esperto pensa di trovarsi sul vero Facebook e inserisce le proprie credenziali.

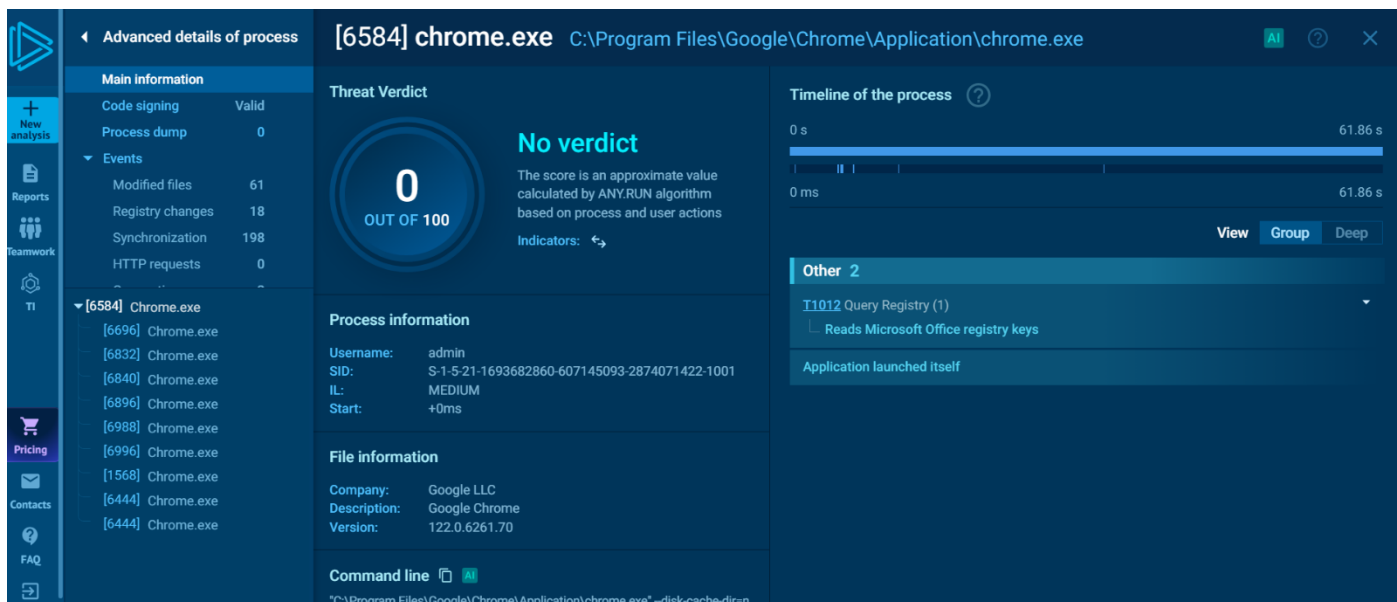


Fase 3 – I processi avviati: Chrome.exe e le sue azioni

Durante l'esecuzione, il processo principale osservato è `chrome.exe` (PID 6584), avviato dall'utente 'admin' con Integrity Level MEDIUM. Chrome genera automaticamente diversi processi figli, ognuno con un ruolo specifico:

- `chrome.exe` (PID 6696) – Gestore dei crash (`crashpad-handler`): monitora gli errori di Chrome e salva i dati nella cartella AppData dell'utente
- `chrome.exe` (PID 6832) – Processo GPU: gestisce il rendering grafico accelerato della pagina
- `chrome.exe` (PID 6840) – Servizio di rete (`NetworkService`): gestisce tutte le connessioni di rete del browser
- `chrome.exe` (PID 6896) – Servizio storage: gestisce la cache e i dati locali del browser
- `chrome.exe` (PID 6988) – Processo renderer: carica e renderizza il contenuto HTML della pagina di phishing

Un dettaglio importante rilevato dalla sandbox: il processo `Chrome.exe` principale esegue una query al registro di sistema leggendo le chiavi di Microsoft Office (T1012 – Query Registry). Sebbene non sia comportamento direttamente malevolo, è un indicatore tipico dei browser moderni che verificano le integrazioni con le suite Office installate.

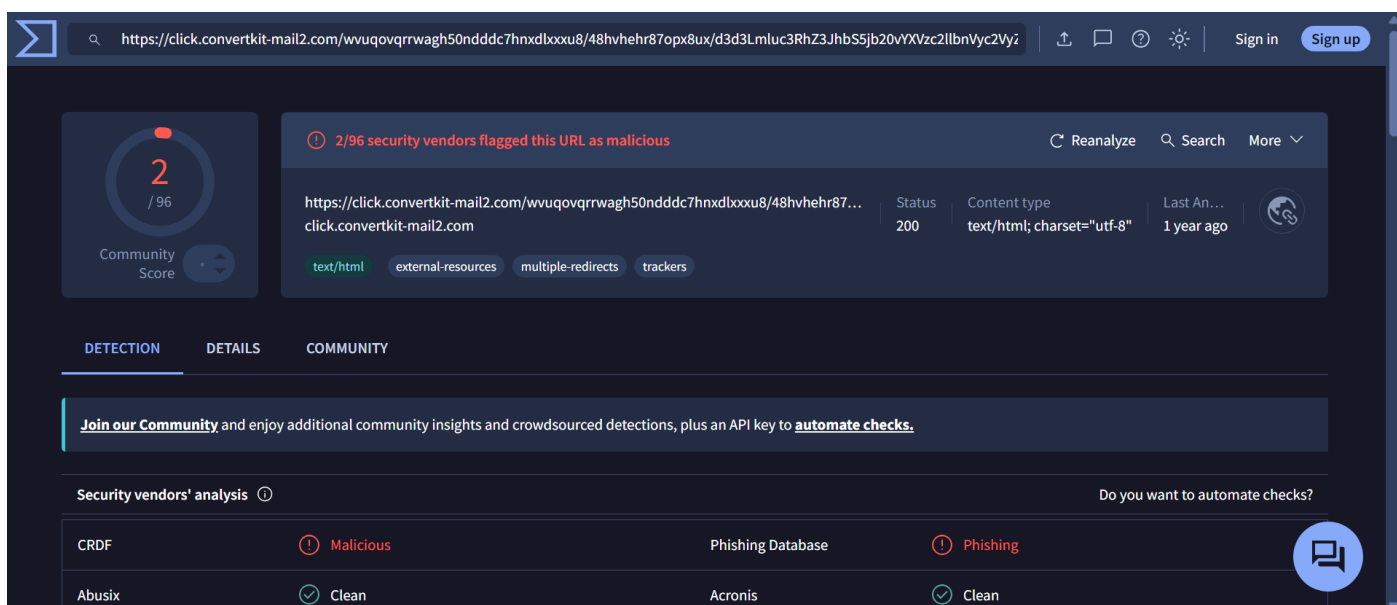


Fase 4 – Il traffico di rete generato

Durante l'esecuzione sono state registrate 48 connessioni di rete, 33 richieste DNS e 3 richieste HTTP. I processi responsabili del traffico di rete sono stati svchost.exe (con una GET HTTP 200 OK verso un server americano) e SIHClient.exe (con due richieste GET HTTP 200 OK verso server tedeschi). Quest'ultimo processo è il Windows Update Health Service, un componente legittimo di Windows.

3.3 Analisi su VirusTotal

Per avere una seconda opinione sulla pericolosità dell'URL, ho sottoposto lo stesso link a VirusTotal, il servizio di scansione multi-vendor che aggrega i risultati di 96 motori antivirus. Il risultato è stato:

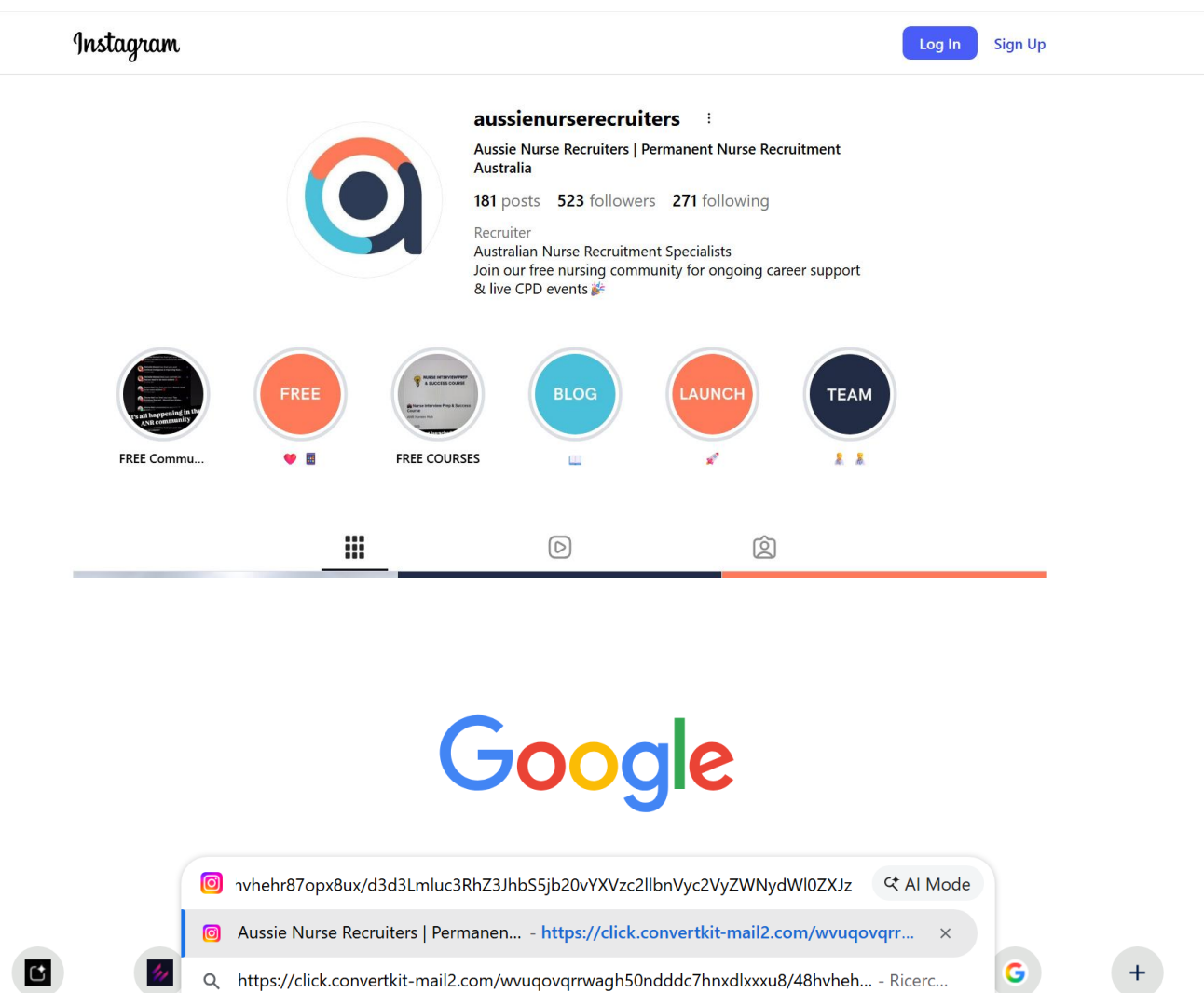


- 2 vendor su 96 hanno segnalato l'URL come malevolo
- CRDF: lo classifica come 'Malicious'
- Phishing Database: lo classifica come 'Phishing'
- I restanti 94 vendor, inclusi nomi come Abusix e Acronis, lo classificano come 'Clean'

L'URL presenta anche le seguenti caratteristiche tecniche su VirusTotal: testo HTML come content type, presenza di risorse esterne, redirect multipli e trackers – tutti elementi coerenti con una campagna di phishing professionale.

3.4 Verifica del Redirect Finale: Instagram Aussie Nurse Recruiters

Seguendo manualmente i redirect dell'URL, la destinazione finale risulta essere la pagina Instagram dell'account '@aussienurserecruiters' (Aussie Nurse Recruiters – Australian Nurse Recruitment Specialists). Questa informazione è confermata anche dalla cronologia del browser mostrata in uno degli screenshot, dove il link convertkit-mail2.com è associato a questa pagina Instagram.



Questo dettaglio è molto importante per l'analisi: l'URL è stato probabilmente inviato via email marketing da questo account e reindirizza al suo profilo Instagram. La pagina Facebook falsa visibile in sandbox potrebbe essere una schermata memorizzata nella cache del browser del sistema di analisi, oppure il comportamento della pagina varia in base all'agente utente o al contesto di navigazione.

Dal Task 2 (di cui ho gli screenshot), i dati tecnici principali del file sottoposto sono:

- MD5: 4C091A5A8C03EBC2EA267980D0DA9F8D
- SHA1: F52CB78B7F23559FFCE5D1125EFD7B399165DFFC
- SHA256: 6DF8AB4ACFC5C751F09F2C8632464C8C5E6DA9D04539A69EDB0FC53CB561DFBC
- SSDEEP:
3:N8UEGGy3i5lbdIJTQTT4SEfGSNscTNKdSVKBf0b/FlzfaLzw/y8aX:2UELmiTQTT4S8G+suGSgh0b/FlzAiaX

ANY

RUN

ANALYZE MALWARE

> Huge database of samples and IOCs

> Custom VM setup

> Unlimited submissions

> Interactive approach

Sign up, it's free

INTERACTIVE MALWARE ANALYSIS

General Behavior MalConf Static information Video Screenshots System events Network

General Info

URL:

https://click.convertkit-mail2.com/vvuqovqrwagh50ndddc7hnxdlxxu8/48hvhvhr87opx8ux/d3d3Lmluc3RhZ3JhbS5jb20vYXVzc2llbnVyc2VyZWNYdWI0ZXJz

Full analysis:

https://app.any.run/tasks/f1f20828-2222-46fb-a886-09f77581e67b

Verdict:

No threats detected

Analysis date:

August 25, 2024 at 22:44:49

OS:

Windows 10 Professional (build: 19045, 64 bit)

Indicators:

MD5:

4C091A5A8C03EBC2EA267980D0DA9F8D

SHA1:

F52CB78B7F23559FFCE5D1125EFD7B399165DFFC

SHA256:

6DF8AB4ACFC5C751F09F2C8632464C8C5E6DA9D04539A69EDB0FC53CB561DFBC

SSDEEP:

3:N8UEGy3i5lbdJTQTT4SEfGSNscTNKdSVKBf0b/FlzfaLzw/y8aX:2UELmiTQTT4S8G+suGSgh0b/FlzAiaX

ANY.RUN

is an interactive service which provides full access to the guest system. Information in this report could be distorted by user actions and is provided for user acknowledgement as it is.

ANY.RUN

does not guarantee maliciousness or safety of the content.

4. Valutazione Finale: Falso Positivo o Vero Positivo?

Questa è la domanda cruciale che ogni analista deve rispondere. Analizziamo i dati disponibili:

ANY.RUN Verdict	No threats detected – Score 0/100 su chrome.exe
VirusTotal	2/96 vendor flaggano come Malicious/Phishing (CRDF e Phishing Database)
Comportamento Visivo	Pagina di login Facebook falsa visibile in sandbox – classico schema di phishing
Redirect Chain	URL obfuscato con redirect multipli e trackers – tecnica evasiva
Destinazione Finale	Profilo Instagram legittimo di un recruiter australiano

4.1 Conclusione: FALSO POSITIVO con Riserva

Sulla base di tutti gli elementi raccolti, la mia valutazione è la seguente:

L'URL analizzato è con alta probabilità un FALSO POSITIVO. Il link appartiene a una campagna di email marketing reale inviata dall'account @aussienurserecruiters tramite ConvertKit, e reindirizza a un profilo Instagram legittimo. Il punteggio di ANY.RUN è 0/100 e solo 2 vendor su 96 lo segnalano (probabilmente per i redirect multipli e i trackers, comportamenti normali nell'email marketing).

Tuttavia, il fatto che la sandbox di ANY.RUN abbia mostrato una pagina di login Facebook durante l'analisi introduce un elemento di incertezza. Questa schermata potrebbe essere:

- Una pagina memorizzata nella cache del browser del sistema virtuale (non correlata al campione)
- Una variante del comportamento dell'URL in base al contesto di navigazione (alcuni siti di phishing mostrano contenuti diversi a seconda del user-agent o dell'IP)
- Un genuino tentativo di phishing mascherato da campagna di marketing legittima

5. Scelte di Remediation e Motivazioni

5.1 Raccomandazione Primaria: Vero Positivo da Investigare Ulteriormente

Considerando il principio di precauzione in ambito cybersecurity (meglio un falso positivo che un vero positivo non rilevato), raccomando di trattare questo caso come un VERO POSITIVO in attesa di ulteriori verifiche, e adottare le seguenti misure:

Azione 1 – Chiedo al Vendor / OSINT

Contatterei il team di sicurezza di ConvertKit per verificare se questo specifico URL è stato effettivamente inviato dall'account @aussienurserecruiters o se il dominio è stato abusato da terzi. Nel frattempo eseguirei analisi OSINT sull'account Instagram per verificarne la legittimità.

Azione 2 – Blacklist temporanea dell'URL

Aggiungerei l'URL specifico a una blacklist temporanea sui sistemi di email filtering e proxy aziendali, in attesa del responso del vendor. I redirect multipli e i trackers rappresentano comunque un comportamento non desiderabile in un contesto aziendale.

Azione 3 – Non mettere in quarantena / Non eliminare

Non procederei con quarantena o eliminazione di sistemi perché l'URL non ha eseguito codice malevolo sul sistema analizzato e ANY.RUN non ha rilevato payload dannosi. Non c'è evidenza di infezione attiva.

Azione 4 – Awareness e comunicazione

Se l'URL è stato ricevuto da utenti aziendali via email, procederei con una comunicazione interna di sensibilizzazione spiegando i rischi del phishing tramite link di email marketing e l'importanza di verificare sempre l'URL prima di inserire credenziali su qualsiasi pagina di login.

6. Riepilogo Indicatori (IOC)

Tipo	Indicatore	Valutazione
Dominio	click.convertkit-mail2.com	Sospetto (usato per phishing)
URL	https://click.convertkit-mail2.com/wvuqov...	2/96 flaggato su VT
MD5	4C091A5A8C03EBC2EA267980D0DA9F8D	Nessun hit su VT
SHA256	6DF8AB4ACFC5C751F09F2C8632464C8...	Nessun hit su VT
Processo	chrome.exe PID 6584	Legittimo – Firma Google LLC valida
Tecnica MITRE	T1012 - Query Registry	Bassa severità
Destinazione	instagram.com/aussienurserecruiters	Profilo legittimo

7. Conclusioni

L'esercizio ha permesso di analizzare un URL sospetto proveniente da una campagna di email marketing e di attraversare l'intero processo di analisi malware: dall'osservazione del comportamento dinamico in sandbox (ANY.RUN), alla verifica multi-vendor (VirusTotal), fino alla valutazione finale e alla scelta di remediation motivata.

Il caso esaminato è un ottimo esempio di come non tutto ciò che viene flaggato sia necessariamente malevolo (potenziale falso positivo), ma allo stesso tempo di come i segnali di rischio – redirect multipli, pagina di login imitata, trackers – non debbano mai essere ignorati senza una verifica approfondita. La sandbox rimane uno strumento fondamentale per osservare il comportamento reale di una minaccia in modo sicuro, prima di prendere qualsiasi decisione operativa.
